

Beyond the Hype: Empirical Analysis of Matter Standard's Security and Privacy

Andrew Losty, Tianrui Hu, Daniel J. Dubois, Narmeen Shafqat, Aanjhan Ranganathan, David Choffnes, Anna Maria Mandalari



Pre-2022 smart home landscape: fragmented, insecure, proprietary

Isolated, incompatible ecosystems (Amazon, Google, Apple, Samsung)

Manufacturers separate device variants per ecosystem

No mandatory security baseline

Cloud-dependent operation – no local control without internet connectivity

Matter (2022): a unified standard

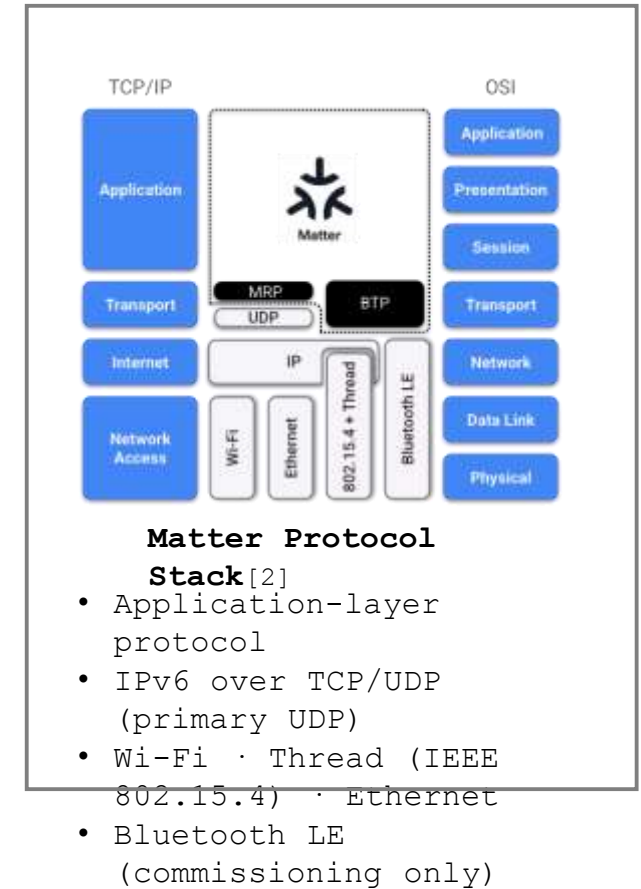
Open, royalty-free specification Connectivity Standards Alliance (CSA)

Native cross-platform operation — single device variant, single SDK

Mandatory certificate-based authentication and end-to-end encryption

Standardized – vendors can contribute to development

Predicted ~473 million devices in 2026, >50% by 2027 [1]



[1] ABI Research, 38 Technology Stats to Know for 2022

[2] Google Home Developers

RQ1: Do Matter-enabled devices offer improved security and privacy compared to similar non-Matter devices?

(Local protocol, encryption, Attestation, Service Discovery, Internet dependency)

RQ2: Do ecosystem-specific interpretations of the Matter standard introduce measurable vulnerabilities in device behavior?

(mDNS advertising, Rotating Device ID, Software Updates, Local Comms, Inferred Version)

RQ3: What are the implications of supporting both the Matter protocol and vendor-specific legacy protocols on IoT devices?

(security models, cloud connections, jurisdiction)

RQ4: How resilient are Matter devices to realistic adversarial actions, such as unauthorized connection attempts and traffic based inference?

(Operational inference, packet reply, commissioning)

University College London



**25 Matter
Devices**

**Bulbs
LED-strips
Smart-plugs
Bridges**

**14 Legacy non-
Matter devices**

**Bulbs
LED-strips
Smart-plugs**

Northeastern



**4 Matter
Controllers**

**Apple
Google
Amazon
Aerotec**

Smartphones

**BluetoothLE
commissioning
Apple
Android**

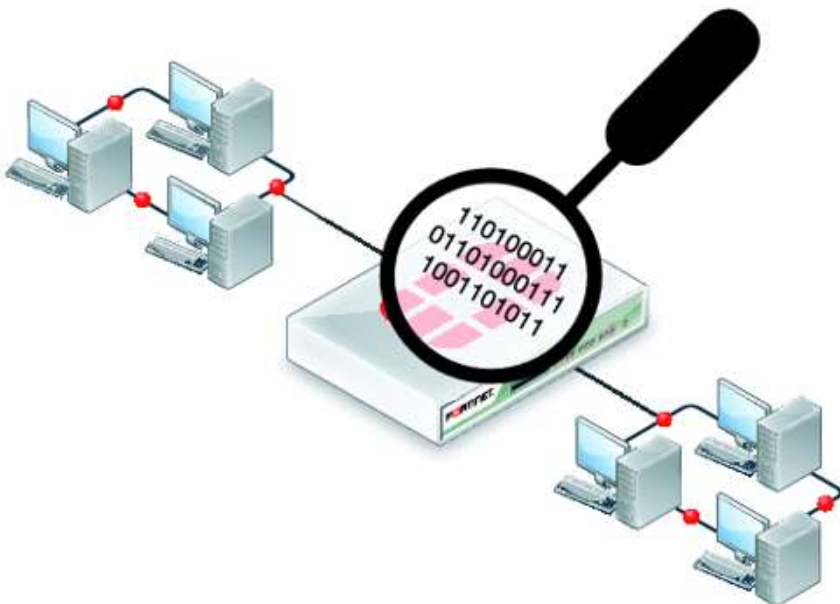
- Factory-reset all 25 Matter + 14 legacy devices before testing.
- Captured BLE commissioning traffic using a Nordic nRF Sniffer.
- Commissioned Matter devices using QR codes or 11-digit PINs across Apple, Google, Amazon, and Aeotec ecosystems.
- Commissioned legacy devices using manufacturer applications.
- Captured Wi-Fi traffic during boot, idle, and active interaction - isolated networks.
- Analyzed traffic in Wireshark, examining unicast, multicast service discovery, and IPv6 addressing.

RQ1 Does Matter offer improved security

Aspect	Non-Matter Devices	Matter Devices
Local Protocol	Varies - often proprietary	Matter port 5540 UDP/TCP
Encryption	Varies - often absent	AES-128-CCM (mandatory) AES-256-CCM (optional)
Service Discovery	Various local protocols	UDP port 5353 (mDNS)
Attestation	Proprietary (if present)	X.509v3 Certificate (DAC)
Internet Dependency	Often required - operation & control	Not required - local-first design

- ✓ Encrypted communication (all tested devices)
- ✓ No plaintext operational commands observed
- ✓ Device authentication via DAC (X.509v3) certificate

✗ Poor Logging verbosity and device visibility



- Re-analysed captures alongside a longitudinal dataset (June 2024–Nov 2025).
- Examined mDNS advertisements for persistent service disclosure and RDI rotation.
- Identified Matter versions using ClusterRevision and mDNS VID/PID fields.
- Measured firmware update behavior, including version changes and update frequency.
- Tested local-first operation after network isolation at reboot, 1 h, and 18 h.



- ✗ Persistent mDNS Advertisements Enable Device Fingerprinting
- ✗ Specification does not tightly define VID/PID advertisements
- ✗ mDNS advertisement intervals are implementation dependent

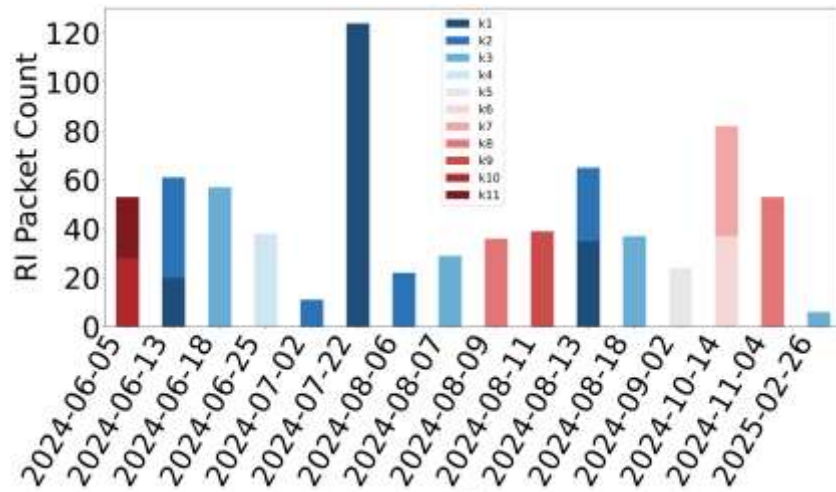
Tapo plug - mDNS post commissioning advertising

Vendor ID: 5010
Product ID: 264
Device Type: 266 Smart-plug
Device Name: Smart Wi-Fi Plug

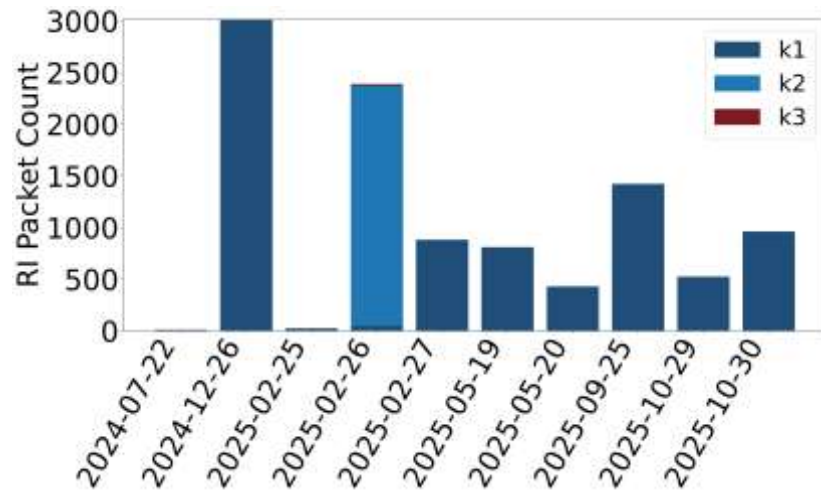


DCL Lookup
webui.dcl.csa-iot.org

**Manufacturer,
Model, SW version,
Certificate ID**



(a) Linkind Matter Plug: 11 rotations over 266 days



(b) Cync Matter Plug: 3 rotations, single key for 263 days

✗ Inconsistent RDI rotation undermines privacy - enables device fingerprinting

✗ RDI exhibits extended lifespan

✗ RDI behavior varies across vendors

Optional security mechanism to prevent long-term cross-network tracking (36-hex-digit string).
Key rotation based on advertising-session counter

(Rotating Device ID - Longitudinal study: June 2024-Nov 2025)



Ver.	Date	Key Changes	New Device Types
1.0	Sep 22	Initial launch	Lights, Switches, Plugs, Locks
1.1	May 23	Battery devices + fixes	—
1.2	Oct 23	New device types	Fans, Vacuums, Detectors
1.3	Apr 24	Energy + scenes grouping	EV Chargers, Appliances
1.4	Nov 24	Energy management expansion	Routers, Solar, Heat Pumps
1.4.1	May 25	Setup + NFC tag support	—
1.4.2	Aug 25	Security + Wi-Fi commissioning	—
1.5	Nov 25	New device types	Cameras, Closures, Soil Sensors
1.6	Jun 26	NFC commissioning, Multi-Admin	—

✗ Matter Versions indistinguishable

ClusterRevision values duplicated -
Network traffic cannot distinguish.

✗ Mixed-version implementations

A device may report an older
ClusterRevision while supporting newer
attributes for backward compatibility.

Matter Basic Information Cluster's
ClusterRevision indicates the Matter
specification version from captured traffic.

ClusterRevision = 1 ⇒ Matter 1.0

ClusterRevision = 2 ⇒ Matter 1.1, 1.2



X Infrequent SW updates, few devices running latest SW.

18 Matter devices only 3 updated.
(Consciot, Orein, Tapo)

6 Matter bridges only 3 updated
(device complexity, dual-protocol support,
need for security patches,

42%

Devices
running
1.0 firmware
(Sep 22)

11%

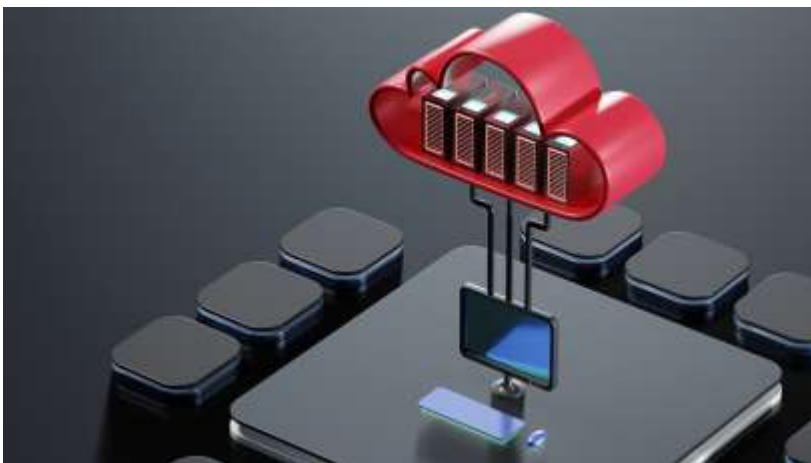
Devices
running
1.4 firmware
(Nov 24)

16%

Devices
Upgraded since
launch

50%

Bridges
Upgraded since
launch



Device	Controllable offline	Post-reboot	After 1 hr	After 18 hrs
Sengled bulb	✓ Yes	✓ Yes (1/2)	✓ Yes (1/2)	✓ Yes
Tapo plug	✓ Yes	✓ Yes (1/2)	✓ Yes (1/2)	✓ Yes
Meross plug	✓ Yes	✓ Yes (1/2)	✓ Yes (1/2)	✓ Yes
Linkind plug	✓ 2s delay	✓ 2s delay	✓ 2s delay	✓ 2s delay
Cync plug	✓ Yes	✓ 30s delay	✓ Yes	✓ Yes
Aqara Bridge	Some features	✓ Yes	Some features	Some features
All other devices/bridges	✓ Yes	✓ Yes	✓ Yes	✓ Yes

Yes(1/2) = control succeeded in 1 of 2 post-reboot / timeout conditions

✓ Validation of Local-First Design

Most devices remained fully functional during offline operation, with no cloud dependency required for core control.

✗ Boot delays - cloud-first firmware

✗ Some vendors treat local operation as fallback, not primary mode

✗ Boot delays add latency before local control becomes available

✗ Inconsistent operation suggests some internet dependence

- Selected seven dual-stack devices — smart plugs, bulbs, and LED strips — supporting Matter and vendor-specific legacy protocols.
- Captured network traffic during device operation on isolated test networks.
- Analyzed destination domains and second-level domains (SLDs) to identify non-Matter cloud endpoints.
- Identified persistent connections to cloud infrastructure operating outside the Matter trust model.
- Assessed identified endpoints for parallel backend infrastructure, potential traffic-interception vectors, and data-jurisdiction implications.



Device	SLDs (Non-Matter)	SLDs (Matter)
TP-Link Bulb	tplinkcloud.com tplinkra.com	tplinknbu.com
Sengled Bulb	sengled.com	amazon.com amazonaws.com
TP-Link Plug	tplinkcloud.com tplinkra.com	tplinknbu.com
Meross Plug	meross.com	meross.com
Tapo Plug	tplinkcloud.com	tplinknbu.com
Tuya Plug	tuyaus.com	N/A
Govee Strip	amazonaws.com govee.com	govee.com

Internet communication destinations (SLDs only)

✗ Persistent cloud connections outside Matter trust model

Parallel backend infrastructure.

✗ Non-Matter devices: cloud man-in-the-middle exposure.

Non-Matter control path: **App** → **Vendor Cloud** → **Device**; cloud services can access device state and user activity

✗ Dual-cloud routing - expands trust domains / attack surface (e.g., Govee).

✗ Cloud Dependence / Availability

✗ Jurisdiction - where user data is processed.

- Captured encrypted Matter traffic over UDP port 5540 during controlled device interactions.
- Analyzed traffic patterns to assess inference of device type, vendor identity, and device state (on/off/dim/hue).
- Evaluated replay-attack resilience using tcpreplay and Scapy against captured control packets.
- Tested unauthorized pairing across three defence layers: physical commissioning-window access, device credentials (QR code/PIN), and network credential requirements.



X Matter is susceptible to inference analysis

Traffic-pattern inference: Vendor-specific packet sizes / sequences - inference without decryption.

User activity inference: Timing patterns can reveal device state changes and user activity. Method also successful for on-off, dim and color change actions.

Example — Off event packet sequence

On/Off events exhibit a consistent sequence of packet sizes, with X and Y being vendor-specific variations:

121	129	X	96	104	96	Y
-----	-----	---	----	-----	----	---

bytes per packet · X, Y = vendor-specific

Encrypted traffic exhibits sufficient operational uniformity to reveal detailed device behavior to an adversary.

~94%

**Distinguish Bulbs
Vs Plugs**

52.6%

**Distinguish based
on MAC OUI**



An in-network adversary retransmits valid messages to trigger unintended device actions

Replay attack (Scapy): Captured Matter messages were retransmitted to test the protocol's replay protection.

✓ Replay attempts failed across all evaluated Matter devices; no messages were accepted or unintended actions triggered.

Matter protection mechanisms

- Per-session message counters
- Counter values are cryptographically bound to the session key



An attacker attempts to commission a Matter device without authorization from the legitimate owner.

Matter's protection mechanism

- | | |
|--------------------------|----------------------|
| • Physical access | Out-of-band action |
| • Device credentials | Setup (QR/number) |
| • Commissioning window | 15 minutes (Default) |
| • Extended Commissioning | 48 Hours (Pid/VID) |

✓ Testing verified
commissioning requires an active window and user interaction (e.g., physical access or setup code)

✗ AiDot-compatible devices permit unauthorized commissioning

Four devices vulnerable to unauthorized pairing via the AiDot APP after Matter commissioning, This is consistent with prior work *.

Key Findings

- Matter raises the IoT security baseline through enforced encryption and authentication — but some security and privacy properties remain heavily vendor-dependent
- Real-world deployments show inconsistent specification adherence and measurable privacy exposure via mDNS.

For Manufacturers

- Limit mDNS advertisements to discovery-required fields only; implement RDI rotation with short lifespans
- Dual-stack devices must not allow non-Matter functionality to undermine Matter security guarantees
- Provide timely Matter specification-version updates with clearly communicated support periods
- Give users control over privacy-sensitive discovery broadcasts

For Standardization & Regulatory Bodies

- Revise mDNS scoping and RDI rotation requirements in the Matter Specification
- Mandate Specification-version currency as a condition of certification renewal

Beyond the Hype: Empirical Analysis of Matter Standard's Security and Privacy

ACM ISBN 979-8-4007-2327-8/26/10

<https://doi.org/10.1145/3777912.3809142>

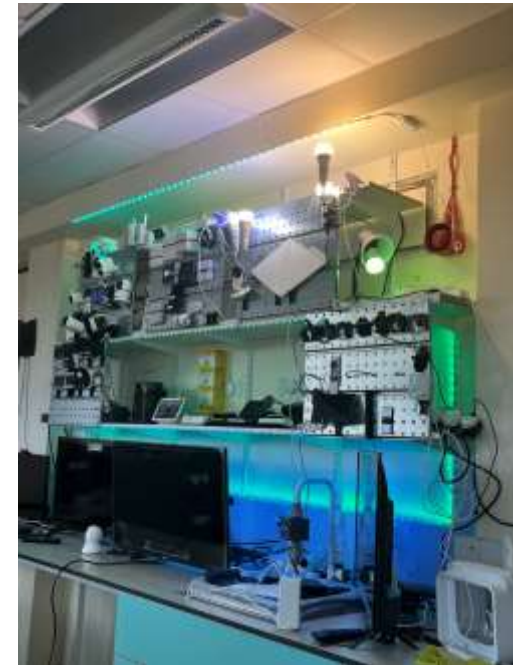
<https://conferences.sigcomm.org/imc/2026/>

Add here QR code to the website page of the paper and link
: <https://safenetiot.github.io/research/Mattersecpriv>

In the website you are missing the link to github under
resources



SafeNetIoT
SECURING THE IOT



Follow us:

<https://safenetiot.github.io/>